

Jeremiah Grossman

Venture capitalist (Grossman Ventures <https://grossman.vc>), Internet protector and industry creator. Founded WhiteHat Security & Bit Discovery. BJJ Black Belt.

THURSDAY, JANUARY 24, 2008

Top Ten Web Hacks of 2007 (Official)



The polls are closed, votes are in, and we have ten winners making up the Top Ten Web Hacks of 2007! The competition was fierce. The information security community put 80 of the newest and most innovative Web hacking techniques to the test. The voting process saw even some attempts at ballot stuffing, but to

no avail, and very few techniques received zero votes. The winners though stood head and shoulders above the rest. Thanks to everyone who helped building the list of links, took the time to vote, and especially the researchers whose work we all rely upon. Congratulations!

Top Ten

1. [XSS Vulnerabilities in Common Shockwave Flash Files](#)
2. [Universal XSS in Adobe's Acrobat Reader Plugin](#)
3. [Firefox's JAR: Protocol issues](#)
4. [Cross-Site Printing \(Printer Spamming\)](#)
5. [Hiding JS in Valid Images](#)
6. [Firefoxurl URI Handler Flaw](#)
7. [Anti-DNS Pinning \(DNS Rebinding \)](#)
8. [Google GMail E-mail Hijack Technique](#)
9. [PDF XSS Can Compromise Your Machine](#)
10. [Port Scan without JavaScript](#)

Honorable Mention:

[Microsoft ASP.NET Request Validation Bypass Vulnerability \(POC\)](#)

The Big List

[Cross-Site Printing \(Printer Spamming\)](#)

[Stealing Pictures with Picasa](#)

[HScan Redux](#)

[ISO-8895-1 Vulnerable in Firefox to Null Injection](#)

[MITM attack to overwrite addons in Firefox](#)

[Microsoft ASP.NET Request Validation Bypass Vulnerability \(POC\)](#)

[Non-Alpha-Non-Digit 3](#)

[Steal History without JavaScript](#)

[Pure Java™, Pure Evil™ Popups](#)

[Google AdSense CSRF hole](#)

[There's an OAK TREE in my blog!?!?!?](#)

[BK for Mayor of Oak Tree View](#)

[Google Docs puts Google Users at Risk](#)

[All Your Google Docs are Belong To US...](#)

[Java Applets and DNS Rebinding](#)

[Scanning internal Lan with PHP remote file opening.](#)



BIO

Jeremiah Grossman brings 20+ years of experience in Computer Security and has become one of the most recognizable and world-renowned cybersecurity experts in the industry, coining several of the original hacking terms commonly used around the world today. Early in his career, Jeremiah was known as "The Hacker Yahoo" which led to his role as the company's Information Security Officer. Jeremiah founded WhiteHat Security (now Synopsis), and served as Chief of Security Strategy for SentinelOne which was the highest-valued cybersecurity IPO in history. Most recently, Jeremiah was the founder & CEO of Bit Discovery, which was acquired by Tenable in 2022. He also serves as a company advisor and board member to several tech startups. In his spare time, Jeremiah does Brazilian Jiu-Jitsu and is passionate about classic cars. He recently opened Toybox, a luxury car club in Boise, Idaho.

LINKS

[Jeremiah Grossman](#)

[Twitter](#)

[Facebook](#)

[LinkedIn](#)

[Grossman Ventures](#)

SUBSCRIBE

 Posts

 Comments

Firefox File Handling Woes
Firefoxurl URI Handler Flaw
Bugs in the Browser: Firefox's DATA URL Scheme Vulnerability
Multiviews Apache, Accept Requests and free listing
Optimizing the number of requests in blind SQL injection
Bursting Performances in Blind SQL Injection - Take 2 (Bandwidth)
Port Scan without JavaScript
Favorites Gone Wild
Cross-Browser Proxy Unmasking
Spoofing Firefox protected objects
Injecting the script tag into XML
Login Detection without JavaScript
Anti-DNS Pinning (DNS Rebinding) : Online Demonstration
Username Enumeration Timing Attacks (Sensepost)
Google GMail E-mail Hijack Technique
Recursive Request DoS
Exaggerating Timing Attack Results Via GET Flooding
Initiating Probes Against Servers Via Other Servers
Effects of DNS Rebinding On IE's Trust Zones
Paper on Hacking Intranets Using Websites (Not Web Browsers)
More Port Scanning - This Time in Flash
HTTP Response Splitting and Data: URI scheme in Firefox
Res:// Protocol Local File Enumeration
Res Timing Attack
IE6.o Protocol Guessing
IE 7 and Firefox Browsers Digest Authentication Request Splitting
Hacking Intranets Via Brute Force
Hiding JS in Valid Images
Internet Archiver Port Scanner
Noisy Decloaking Methods
Code Execution Through Filenames in Uploads
Cross Domain Basic Auth Phishing Tactics
Additional Image Bypass on Windows
Detecting users via Authenticated Redirects
Passing Malicious PHP Through getimagesize()
Turn Any Page Into A Greasemonkey Popup
Enumerate Windows Users In JS
Anti-DNS Pinning (DNS Rebinding) + Socket in FLASH
Iframe HTTP Ping
Read Firefox Settings (PoC)
Stealing Mouse Clicks for Banner Fraud
(Non-Persistent) Untraceable XSS Attacks
Inter Protocol Exploitation
Detecting Default Browser in IE
Bypass port blocking in Firefox, Opera and Konqueror.
LocalRodeo Detection
Image Names Gone Bad
IE Sends Local Addresses in Referer Header
PDF XSS Can Compromise Your Machine
Universal XSS in Adobe's Acrobat Reader Plugin
Firefox Popup Blocker Allows Reading Arbitrary Local Files
IE7.o Detector
overwriting cookies on other people's domains in Firefox.
Embedding SVG That Contains XSS Using Base64 Encoding in Firefox
Firefox Header Redirection JavaScript Execution
More URI Stuff... (IE's Resource URI)
Hacking without odays: Drive-by Java
Google Urchin password theft madness
Username Enumeration Vulnerabilities
Client-side SQL Injection Attacks
Content-Disposition Hacking
Flash Cookie Object Tracking
Java JAR Attacks and Features
Severe XSS in Google and Others due to the JAR protocol issues
Web Mayhem: Firefox's JAR: Protocol issues (bugzilla)
oDAY: QuickTime pwns Firefox
Exploiting Second Life

6 comments:

[John](#) said...



http://digg.com/security/Top_Ten_Web_Hacks_of_2007

[January 24, 2008 at 8:45 PM](#)

Anonymous said...

Interesting. Could you elaborate more on the sampling? For instance, how many total votes, what's the distribution and spread, how long was the poll open, what this self-selected, advertised anywhere?

thanks.

[January 25, 2008 at 10:57 AM](#)

[Jeremiah Grossman](#) said...



Its difficult for me to pull out the individual numbers from Survey Monkey, but I can give you some estimates and NO this was NOT self-selected. 2006 was more of less.

Over 50 people voted and polls were open about a week. Voting was advertised on my blog (and others), the web security mailing list, and emailed directly to several of my personal contacts. Word got around.

The lowest techniques on the list got about 10 votes, while the highest 20+, the rest obviously fell somewhere in the middle. Most of the remainder were in the 2-5 vote area.

[January 25, 2008 at 11:44 AM](#)

Anonymous said...

Poor poll! Wrong urls, "techique vs hack" misconception, miscredited stuff.

Not a good job at all.

[January 27, 2008 at 7:54 AM](#)

Anonymous said...

Thanks for the Top Ten list!
Its brilliant,

Amazing post!

Cheers,

Jenna

[September 24, 2008 at 11:46 AM](#)

Anonymous said...

Thanks for the list

[March 23, 2009 at 7:32 AM](#)

[Post a Comment](#)

[Newer Post](#)

[Home](#)

[Older Post](#)

Subscribe to: [Post Comments \(Atom\)](#)

This site uses cookies from Google to deliver its services and to analyse traffic. Your IP address and user agent are shared with Google, together with performance and security metrics, to ensure quality of service, generate usage statistics and to detect and address abuse.

[LEARN MORE](#) [GOT IT](#)